Aviral Srivastava

Security Researcher | AI/ML Infrastructure Security | Vulnerability Research | Offensive Security

+1 814 769 6414 aviralyash27@gmail.com aviralsrivastava.tech
linkedin.com/in/aviralsrivastava23 github.com/Aviral2642 Speaker Profile

Recognition

Pwnie Awards 2026 Nominee, Best Server-Side / Cloud Bug, for Langflow unauthenticated RCE (CVE-2026-33017).

CVE-2026-33017 added to the **CISA Known Exploited Vulnerabilities catalog**. Sysdig documented exploitation within 20 hours of disclosure.

First AI-security framework mapping accepted into the **NIST OLIR catalog**. Listed Point of Contact on NIST CSRC.

RSA Security Scholar 2025. Selected for the conference's university-nominated cybersecurity scholar program.

Vulnerability Research and Coordinated Disclosure

10 assigned CVEs (9 published, 1 allocated); **6 other accepted findings without CVEs**; **6 gateway reports awaiting review**. Status as of November 8, 2026 (Pacific time).

CVE-2026-33017 | **Langflow** | Unauthenticated RCE | *9.3 Critical; published, CISA KEV*

CVE-2026-32628 | **AnythingLLM** | SQL injection in SQL Agent | *High; published*

CVE-2026-53923 | **vLLM** | GPU memory disclosure | *5.3 Medium; published*

CVE-2026-69258 | **Flowise** | Execution-context property injection | *8.8 High; published*

CVE-2026-73081 | **Activepieces** | Pre-sandbox command injection | *8.7 High; published, co-reported*

CVE-2026-73083 | **Activepieces** | V8 isolate bypass | *7.6 High; published, co-reported*

CVE-2026-73084 | **Activepieces** | OAuth redirect XSS | *6.1 Medium; published*

CVE-2026-104850 | **MCP TypeScript SDK** | OAuth credential exposure | *7.5 High; published, co-reported*

CVE-2026-115563 | **MCP Python SDK** | OAuth credential exposure | *7.5 High; published, co-reported*

CVE-2026-121991 | **Apache HTTP Server** | TLS 1.3 post-handshake use-after-free | *Allocated Nov 4; not yet public*

Accepted findings without assigned CVEs (6)

oauth2-proxy — Authentication bypass; Critical 9.1. Published; CVE requested.

authentik — Critical 9.1; accepted, CVE requested; advisory not public (`GHSA-55mc-jpww-xm3p`).

Agent402 — Two confirmed findings, fixed in 0.8.23 and published Nov 6: `GHSA-4c67-hp39-v8x2` and `GHSA-mgfm-63c3-pg7v`. No CVEs assigned.

PHP-FPM — Report consolidated with an earlier finding; reporter-credit invitation and fix work confirmed (`GHSA-qc49-hpvq-g2w6`). No CVE assigned.

Grafana — Alert-rule folder permission bypass accepted by Intigriti on Sep 30 (`GRAFANALABS-48OJT3W8`). No CVE assigned.

Submitted, awaiting acceptance (6)

Agent Router: route-scoped JWT bypass; **LiteLLM**: MCP toolset widening, WebSocket authorization, and batch authorization scope; **Kong**: prompt guard bypass; **Apache APISIX**: prompt guard coverage. All six await vendor acceptance.

- **Press.** MCP Python SDK research covered by **The Hacker News**. Langflow discovery covered by **The Hacker News**, **Help Net Security**, **Infosecurity Magazine**, **Sysdig**, and **Qualys ThreatProtect**.

Experience

Amazon **Aug 2025 – Present**

Security Engineer (L4), Ads Product Security *Sunnyvale, CA*

- Lead application security reviews across advertising platforms via source code analysis, threat modeling, and penetration testing, partnering with engineering on remediation before launch.
- Own AI/ML security assessment for customer-facing products across prompt injection, cross-tenant data leakage, agentic workflow abuse, and RAG hardening.
- Built an org-wide threat modeling tool, reducing assessment turnaround from days to hours.

Standards Body Contributions

- **NIST Online Informative References Catalog.** OWASP LLM Top 10 v2.0 to NIST CSF 2.0: 169 relationships covering 77 of 106 subcategories. Published April 2026; listed Point of Contact on NIST CSRC.
- **MITRE CWE and CAPEC.** Three submissions in Phase 3 analyst review covering AI workflow logic isolation, silent tensor metadata truncation, and a matching attack pattern.
- **NIST SP 1347.** Formal public comment on the CSF Informative References Quick-Start Guide, addressing AI/ML reference gaps.

Invited Talks

- **BSides Las Vegas 2026**, Breaking Ground. *Rejected-Input Programming: Exploiting Parsers That Say No Too Late.*
- **RSA Conference 2026.** *From Prompt to Pager: Preparing for AI-Native Incidents Now.* **ISACA North America 2026.** *Breaking the Loop: Offensive Testing of RL and Agentic AI Systems.*
- **CactusCon 14 (2026)** and **13 (2025)**, **CypherCon 2025**, **HOPE XV**, **BSides** Salt Lake City, Twin Cities, Chicago, Bangalore.

Research, Publications, and Open Source

- **20+ peer-reviewed publications** and **2 granted patents** across ML for threat detection, cryptography, and malware analysis. Poster accepted at the **NeurIPS** Red Teaming GenAI workshop.
- **Co-authored textbooks:** *Machine Learning for Hackers* and *Internet of Things* (RLK Enterprises, 2023), first author on the latter.
- Peer reviewer: **NeurIPS**, **ACM**, **IEEE**. MS thesis: LLM-generated cryptographic CTF challenges.
- **Public research:** **AI Infrastructure Security**, **Kernel n-day Analysis**, and an audit of **221 integer truncation sites in vLLM**.
- **Open source:** **AdversaryPilot** (ATLAS-aligned planning for LLM/agent systems); **KernelGhost** and **ZeroDayForge** (historical systems and exploitation research).

Education

The Pennsylvania State University, MS Cybersecurity Analytics and Operations, GPA 4.0 May 2025

Amity University, BTech Computer Science Jul 2023

Awards and Credentials

- **Cybersecurity Innovator of the Year**, BSides Bangalore. **Hack The Box:** Guru, AviralxRoot.
- **OSCP** (Offensive Security Certified Professional). **CCSK v5** (Cloud Security Alliance).

Technical Skills

Languages: C, C++, Python, x86 Assembly, JavaScript, Bash, SQL

Vulnerability Research: Memory corruption, exploit development, reverse engineering, kernel and hypervisor internals, parser and deserialization security, fuzzing, GPU memory analysis. IDA Pro, Ghidra, radare2, ASAN, libFuzzer

AI/ML Security: LLM and GenAI attack surface, prompt injection, agentic workflow abuse, MCP and OAuth trust boundaries, RAG risk assessment, model file and tokenizer security, inference engine internals

AppSec and Frameworks: Secure SDLC, threat modeling, SAST/DAST, API security. MITRE ATT&CK, ATLAS, NIST CSF 2.0, OWASP LLM Top 10, CWE, CAPEC, CVSS v4